

Introduction to AI Threat Modeling

CompTIA SecAI+: AI Security Certification Complete Exam Prep 2026 | Section 10: AI Threat Modeling Resources

1. Why AI Threat Modeling Is a Distinct Discipline

Traditional threat modeling—frameworks such as STRIDE, attack trees, and DREAD—was designed for software applications, network architectures, and IT infrastructure. Those environments present relatively stable attack surfaces: authentication endpoints, protocol stacks, network perimeters. AI systems add a dynamic, probabilistic layer that changes every time the model is retrained or fine-tuned. The model itself becomes an asset that can be interrogated, manipulated, and stolen. Training data becomes an attack surface that existed long before a single line of code was written. These properties mean that traditional threat modeling, while still necessary, is no longer sufficient on its own. Practitioners must extend their thinking to include the entire AI lifecycle—from data collection through decommissioning—rather than focusing narrowly on runtime behavior.

A key mindset shift is recognizing that AI attacks do not always look like intrusions. Adversarial inputs arrive as ordinary user requests. Data poisoning occurs inside a legitimate data pipeline. Model extraction happens through authorized API calls. Without AI-specific threat modeling, these attack vectors are routinely overlooked during security reviews.

2. The Five AI Attack Surfaces

Attack Surface	What It Covers	Example Threat
Training Data	Datasets used to teach the model	Data poisoning — injecting mislabeled malware samples
Training Process	Pipelines, compute infrastructure, orchestration	Unauthorized code insertion; gradient leakage during federated learning
Trained Model	Model weights, architecture, serialized files	Model theft via API extraction; weight tampering in storage
Inference Inputs	Queries submitted to the deployed model	Adversarial examples crafted to evade detection
Model Outputs	Predictions, confidence scores, generated text	Membership inference; sensitive data leakage in responses

Mapping each component of an AI system to one of these five surfaces is often the first practical step in an AI threat modeling session. Once the surface is identified, teams can apply established attack taxonomies—such as MITRE ATLAS or the OWASP ML Top 10—to enumerate plausible threats for that surface.

3. Structured Questions That Drive Every Threat Model

Effective threat modeling is guided by a consistent set of questions rather than free-form brainstorming. The following sequence applies to AI systems at any scale:

- What assets require protection? — Model weights, training datasets, inference APIs, output data, operational metadata.
- Who are the realistic threat actors? — External attackers, malicious insiders, competitors, nation-state actors, accidental misuse.
- What are their motivations and capabilities? — Evasion, IP theft, sabotage, competitive intelligence, regulatory non-compliance.
- How could each threat actor carry out an attack against each asset? — Map actors to attack surfaces and then to specific techniques.
- What security controls already exist? — Authentication, encryption, access controls, anomaly detection, human review.
- Where are the gaps? — Unprotected surfaces, weak controls, missing monitoring.
- What would be the business impact if each threat were realized? — Financial loss, regulatory penalty, reputational damage, operational disruption.

Documenting answers to these questions creates a structured risk register that can be updated as the AI system evolves and new threats emerge.

4. Threat Actors Targeting AI Systems

Actor	Primary Goal	Likely Techniques
External attacker	Evade AI-based security controls	Adversarial inputs, model probing
Malicious insider	Sabotage or data theft	Training data manipulation, model exfiltration
Competitor	IP theft	Model extraction via API queries
Nation-state	Critical infrastructure disruption	Supply chain poisoning, sustained model probing
Accidental misuser	Unintentional exposure	Misconfiguration, over-privileged API access

5. AI-Specific Threat Categories

Beyond the traditional CIA triad, AI systems introduce five additional threat categories that every practitioner must understand:

- **Data Poisoning:** Manipulation of training data to cause the model to learn incorrect behavior. Impacts model integrity before deployment.
- **Adversarial Evasion:** Crafting inputs that cause the model to misclassify during inference. Impacts model availability and reliability at runtime.
- **Model Theft:** Extracting a functional replica of a proprietary model through API interaction. Impacts intellectual property and competitive advantage.
- **Privacy Attacks:** Inferring sensitive information about training data by observing model outputs. Impacts data confidentiality.
- **Backdoor Attacks:** Embedding hidden trigger-based behaviors during training that activate only under specific conditions. Impacts model integrity and trustworthiness.

Real-World Incident — Microsoft Tay (2016): Microsoft's conversational AI 'Tay' was manipulated through coordinated user inputs within hours of launch. Users deliberately fed the system offensive and extremist content, exploiting the model's online learning capability to corrupt its outputs. The incident illustrates how inference inputs and online training pipelines can be weaponized simultaneously—a scenario that a thorough threat model should anticipate before deployment.

6. Impact and Likelihood Assessment

Identifying threats is only the beginning. Security resources are finite, so teams must prioritize risks based on two dimensions: business impact and likelihood of exploitation.

Business impact assessment asks what would happen to operations, customers, revenue, and regulatory standing if a specific threat were realized. A successful adversarial attack against a malware classifier, for example, could result in undetected infections, operational disruption, and potential breach notification obligations—a high-impact outcome.

Likelihood assessment evaluates the attacker's motivation, technical capability, available resources, and the presence or absence of existing controls. An AI system trained on publicly sourced data faces a higher likelihood of data poisoning than one using tightly controlled internal datasets. Threat intelligence provides context about whether similar attacks are already occurring in the wild.

Risk Priority	Impact	Likelihood	Recommended Response
Critical	High	High	Immediate mitigation; accept residual risk only with executive sign-off
High	High	Low	Mitigate during next development cycle; monitor closely
Medium	Low	High	Implement detective controls; schedule targeted mitigation
Low	Low	Low	Accept with documented rationale; review annually

7. The Value of Continuous Threat Modeling

Core Principle: A threat model completed once at system design is out of date before the system reaches production. AI threat modeling must be continuous because models are retrained, data sources change, infrastructure evolves, and attackers develop new techniques.

Many mature security organizations combine scheduled formal reviews—typically quarterly—with event-driven reviews triggered by significant architectural changes, major security incidents, or newly published AI attack techniques. Embedding threat modeling into CI/CD pipelines for AI systems ensures that every retrain or model update receives at least a lightweight security review. The output of each review updates the living threat model documentation rather than creating a new standalone document.

8. Practical Threat Modeling Steps for AI Systems

- Step 1 — Identify components: Map all data sources, training pipelines, model storage, inference endpoints, and output consumers.
- Step 2 — Create a data flow diagram: Visualize how information moves through the system, including trust boundaries and external connections.
- Step 3 — Identify assets and threat actors: Determine what is worth protecting and who is realistically motivated to attack it.
- Step 4 — Apply threat frameworks: Use OWASP ML/LLM Top 10, MITRE ATLAS, STRIDE, or PASTA to enumerate specific threats for each component.
- Step 5 — Assess impact and likelihood: Prioritize threats using a risk matrix rather than treating all risks equally.
- Step 6 — Define mitigations and controls: Assign specific security controls to each prioritized threat, with ownership and timelines.
- Step 7 — Document and review: Maintain a living threat model that is updated after system changes, incidents, and scheduled reviews.

9. Threat Modeling Documentation Standards

Documentation transforms a threat modeling session into a durable security artifact. A complete AI threat model document should contain the following sections: an asset inventory, a data flow diagram, a list of threat actors with motivation profiles, an enumerated threat register with risk ratings, a mapping of existing controls to each threat, a gap analysis, and a remediation roadmap with ownership. This documentation serves multiple purposes beyond the immediate security review. It supports architecture decisions, informs penetration testing scope, guides compliance activities, and provides institutional memory when team members change. Well-maintained documentation also makes regulatory audits significantly less disruptive because security reasoning is already recorded.

10. Multi-Disciplinary Stakeholder Involvement

AI threat modeling is most effective when it brings together professionals from multiple disciplines rather than being conducted by a single team. Each stakeholder group contributes knowledge that others cannot replicate:

- Data scientists understand how models are trained, which data sources are used, and how changes to training data affect model behavior.
- Security engineers understand attack techniques, threat intelligence, and how existing controls can be applied to new surfaces.
- Software and ML architects understand system design, trust boundaries, and integration points that create attack opportunities.
- Business owners understand operational priorities, acceptable risk levels, and the business consequences of specific attack scenarios.
- Security analysts understand how the AI system interacts with the broader security operations environment it is designed to support.

Structuring threat modeling as a collaborative workshop rather than a solo analysis ensures that no significant attack surface is overlooked and that risk ratings reflect operational reality.

11. Analogy — Threat Modeling as Pre-Flight Inspection

Think of AI threat modeling as the pre-flight inspection a pilot performs before every flight. The aircraft may have been flying safely for months, but each inspection checks for new wear, unexpected damage, and correct configuration before trusting the system with passengers. Skipping the inspection because 'everything was fine yesterday' is how accidents happen. In the same way, AI systems that operated securely last quarter may face new risks today because the model was retrained on new data, a new API endpoint was exposed, or a new adversarial technique was published. Continuous threat modeling is the pre-flight inspection of AI security—non-negotiable and repeated every time significant changes occur.

Key Terms Glossary

Term	Definition
Threat Modeling	A structured process for identifying, quantifying, and prioritizing potential threats to a system during design and throughout its lifecycle.
Attack Surface	The sum of all points in a system where an attacker could attempt to input, extract, or manipulate data.
Adversarial Input	A crafted input designed to cause an AI model to produce an incorrect or attacker-desired output.
Data Poisoning	An attack in which malicious data is introduced into a training dataset to corrupt model behavior.
Threat Actor	An individual or group that has the motivation, capability, and opportunity to carry out an attack.
Impact Assessment	The process of evaluating the potential business consequences if a specific threat is successfully exploited.
Likelihood Assessment	The process of evaluating how probable it is that a specific threat will be exploited given current conditions and controls.
Risk Register	A documented inventory of identified risks, their ratings, existing controls, and planned mitigations.
STRIDE	A threat categorization framework covering Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, and Elevation of Privilege.
MITRE ATLAS	A knowledge base of adversarial tactics and techniques targeting AI systems, modeled after MITRE ATT&CK.
Backdoor Attack	An attack that embeds a hidden trigger in a model during training so that the model behaves normally except when a specific input condition is present.
Continuous Threat Modeling	The practice of reviewing and updating a threat model regularly throughout a system's lifecycle rather than performing a single assessment at design time.

Quick Revision Checklist

- AI threat modeling extends traditional approaches by addressing training data, model weights, and inference inputs as distinct attack surfaces.
- Five major AI attack surfaces: training data, training process, trained model, inference inputs, model outputs.
- Five AI-specific threat categories: data poisoning, adversarial evasion, model theft, privacy attacks, backdoor attacks.
- Threat modeling questions cover: assets, threat actors, motivations, attack paths, existing controls, gaps, and business impact.
- Threat actors include external attackers, malicious insiders, competitors, nation-state actors, and accidental misusers.
- Risk prioritization uses both business impact and likelihood; neither dimension alone is sufficient.
- Threat modeling must be continuous — scheduled reviews plus event-driven reviews after system changes or new techniques.
- Documentation creates a living security artifact that supports architecture, compliance, testing, and institutional memory.
- Multi-disciplinary teams (data scientists, security engineers, architects, business owners, analysts) produce more complete threat models.
- Frameworks such as OWASP ML/LLM Top 10 and MITRE ATLAS provide structured enumeration of AI-specific threats.

10 Exam-Based MCQs — AI Threat Modeling Fundamentals

Test yourself after reading. These questions are written in real exam style — scenario-heavy, with plausible distractors. Read every explanation, including for questions you answered correctly.

Q1. Scenario: A financial services company is deploying an AI-powered fraud detection model trained on two years of transaction records. The security team has been asked to conduct an AI threat model before the system goes live. No prior AI threat model exists for this type of system. Which action should the security team take FIRST when beginning an AI threat modeling exercise for a new fraud detection model?

- A) Run a penetration test against the deployed model's API
- B) Identify the model's major components, data sources, and data flows
- C) Apply STRIDE categories to the model's output layer
- D) Assess the likelihood of adversarial evasion attacks

Answer: B **Explanation:** B is correct because identifying components, data sources, and data flows is the foundational step — without this map, threat enumeration has no structure. A is incorrect because penetration testing is a validation activity performed after threat modeling, not a substitute for it. C is incorrect because applying STRIDE categories before mapping components risks missing entire attack surfaces. D is incorrect because likelihood assessment occurs after threats have been identified.

Q2. Scenario: During the AI threat modeling session, a data scientist explains that the fraud detection model is automatically retrained every week. Training data is pulled via API from a third-party data aggregator that consolidates transaction records from multiple financial institutions. The security team discovers that the fraud detection model is retrained weekly using transaction data pulled automatically from a third-party data broker. Which threat category is MOST directly relevant to this configuration?

- A) Adversarial evasion
- B) Model theft
- C) Data poisoning via supply chain
- D) Membership inference

Answer: C **Explanation:** C is correct because the third-party data broker represents an external supply chain dependency — if that source is compromised or manipulated, poisoned data could enter the training pipeline directly. A is incorrect because adversarial evasion targets inference inputs, not the training pipeline. B is incorrect because model theft involves copying the trained model, not corrupting its training data. D is incorrect because membership inference is a privacy attack that probes the deployed model, not a risk associated with the training data supply chain.

Q3. Scenario: The threat modeling team is reviewing how the deployed fraud detection model is exposed through an external REST API. A security engineer notes that authorized partners have direct query access and that no usage quotas currently exist. The team wants to identify and control the most significant risk this configuration presents. The threat model identifies a risk where an attacker with authorized API access submits thousands of carefully crafted queries to deduce the model's decision boundary. What type of attack does this represent, and what is the BEST primary control?

- A) Data poisoning — implement input validation on training pipelines
- B) Model theft via extraction — implement API rate limiting and usage monitoring
- C) Adversarial evasion — implement adversarial training on the model
- D) Membership inference — implement differential privacy during training

Answer: B **Explanation:** B is correct because repeatedly querying a deployed model to deduce its behavior and build a replica is model extraction (model theft). Rate limiting restricts the number of queries an attacker can submit, and usage monitoring detects abnormal query patterns. A is incorrect because data poisoning targets training pipelines, not API query behavior. C is incorrect because adversarial evasion aims to fool the model's predictions, not copy them. D is incorrect because membership inference determines whether specific records were in the training set, which is a different objective from building a model replica.

Q4. Which statement BEST describes why AI threat modeling should be treated as a continuous process rather than a one-time activity?

- A) Regulatory frameworks require threat models to be re-submitted annually
- B) AI models change through retraining, new data sources, and infrastructure updates, and attackers develop new techniques over time
- C) Penetration testing vendors require updated threat models before each engagement

D) Continuous threat modeling satisfies the model explainability requirements of AI governance frameworks

Answer: B **Explanation:** B is correct because AI systems are inherently dynamic — models are retrained, new data sources are added, infrastructure evolves, and the threat landscape changes. A static threat model quickly becomes an inaccurate representation of the system's actual risk profile. A is incorrect because while some regulations encourage periodic reviews, regulatory cadence is not the primary technical reason for continuous threat modeling. C is incorrect because penetration test scheduling is a project management concern, not the rationale for continuous threat modeling. D is incorrect because model explainability is a governance and interpretability concept, not a function of the threat modeling process.

Q5. Which five attack surfaces are unique to AI systems and should be added to a traditional threat model when securing an AI-powered security tool?

- A) Authentication, authorization, encryption, network perimeter, and application code
- B) Training data, training process, trained model, inference inputs, and model outputs
- C) Data warehouse, ETL pipeline, API gateway, message queue, and storage layer
- D) Model accuracy, precision, recall, F1 score, and AUC-ROC

Answer: B **Explanation:** B is correct — these are the five major AI-specific attack surfaces identified in AI threat modeling. A is incorrect because those are standard IT security concerns, not AI-specific attack surfaces. C is incorrect because those are generic data architecture components, not specific to AI threat modeling. D is incorrect because those are model performance metrics, not security attack surfaces.

Q6. Which threat actor profile is MOST likely to conduct a sustained model extraction attack against a commercial AI-powered threat intelligence platform?

- A) An accidental misuser who submits an unusually large number of queries
- B) A nation-state actor targeting public infrastructure
- C) A competitor seeking to replicate the platform's proprietary detection logic
- D) A malicious insider manipulating the training dataset

Answer: C **Explanation:** C is correct because model extraction is primarily motivated by the desire to obtain proprietary capabilities without the investment required to develop them. A competitor seeking to replicate detection logic has a clear motive, the technical capability to execute API-based extraction, and a financial incentive. A is incorrect because accidental misusers act without malicious intent. B is incorrect because nation-state actors typically target critical infrastructure disruption rather than commercial IP theft. D is incorrect because a malicious insider would manipulate training data from within the organization rather than conducting an external extraction attack.

Q7. What is the PRIMARY purpose of a data flow diagram in the context of AI threat modeling?

- A) To document the mathematical transformations applied during model training

- B) To visualize how data moves through the system and identify trust boundaries where attacks could occur
- C) To specify the monitoring thresholds for anomaly detection in production
- D) To record the business impact ratings assigned to each identified threat

Answer: B **Explanation:** B is correct because a data flow diagram (DFD) maps information flows and trust boundaries—the points where data crosses from a trusted zone to a less-trusted zone—making it possible to identify where attackers could intercept, modify, or inject data. A is incorrect because mathematical transformations are described in model documentation, not DFDs. C is incorrect because monitoring thresholds are operational configurations, not DFD content. D is incorrect because business impact ratings belong in the risk register, not the DFD.

Q8. A backdoor attack is BEST described as which of the following?

- A) An attacker gaining unauthorized administrative access to the model's hosting infrastructure
- B) A hidden behavior embedded in a model during training that activates only when a specific trigger input is present
- C) An attacker intercepting model outputs and modifying them before they reach downstream systems
- D) A technique for reconstructing sensitive training records from model responses

Answer: B **Explanation:** B is correct — a backdoor attack (also called a trojan attack) involves embedding a hidden conditional behavior during training so the model behaves normally in all circumstances except when the trigger is present. A is incorrect because that describes unauthorized access to infrastructure, not a backdoor attack on the model itself. C is incorrect because that describes an output integrity attack. D is incorrect because that describes a model inversion or membership inference attack.

Q9. During a threat modeling workshop, the business owner argues that risk prioritization should focus only on high-likelihood threats. The security engineer disagrees. Which position is MOST accurate?

- A) The business owner is correct — low-likelihood threats waste security budget and should be removed from the register
- B) The security engineer is correct — risk must account for both impact and likelihood; a low-likelihood but catastrophic threat may still warrant controls
- C) Neither position is correct — threat modeling ranks risks by the technical sophistication of the attack, not by business factors
- D) Both are correct — organizations should maintain two separate risk registers, one for high-likelihood and one for high-impact threats

Answer: B **Explanation:** B is correct because risk is the product of both impact and likelihood. A threat with low probability but catastrophic impact (e.g., model backdoor activating during a high-stakes decision) may justify significant investment despite its low likelihood. A is incorrect because eliminating low-likelihood threats from consideration ignores tail risks that can be catastrophic. C is incorrect because technical sophistication is a component of likelihood assessment, not a standalone ranking criterion. D is

incorrect because maintaining separate registers creates confusion and risks missing the interaction between impact and likelihood.

Q10. Which element is LEAST likely to be found in a completed AI threat model document?

- A) A data flow diagram showing trust boundaries
- B) A risk register with threat ratings, existing controls, and planned mitigations
- C) The hyperparameter configuration used during the last model training run
- D) A threat actor profile section describing likely adversaries and their motivations

Answer: C **Explanation:** C is correct — hyperparameter configurations are model development artifacts stored in experiment tracking systems, not security threat model documentation. A is incorrect because DFDs are a standard component of threat model documents. B is incorrect because a risk register is the core output of a threat modeling exercise. D is incorrect because threat actor profiles are a standard section in any complete threat model.